

Reporte Ejecutivo de Auditoría de Seguridad

1. Resumen Ejecutivo

Score de Seguridad General: 60 / 100

Justificación del Score: La puntuación se deduce principalmente por la exposición de servicios internos críticos (resolvedor DNS local y cliente DHCP) a la red, lo que representa una superficie de ataque innecesaria y significativa. Adicionalmente, se identificó una configuración inusual en la shell de un usuario de sistema, lo que sugiere una gestión de cuentas subóptima.

Evaluación Gerencial

El servidor auditado opera con una versión reciente y soportada de Ubuntu (24.04.4 LTS) y su kernel (6.8.0-124-generic), lo cual es positivo para la estabilidad y el soporte de seguridad. Sin embargo, el análisis revela deficiencias significativas en la configuración de red y la gestión de cuentas de usuario. La exposición de servicios como el resolvedor DNS local (systemd-resolve) y, más críticamente, el cliente DHCP (systemd-network) a la red externa, crea vectores de ataque importantes. Además, se encontró una configuración atípica para un usuario de sistema que, aunque no concede acceso interactivo directo, indica una posible mala práctica. El servicio SSH está activo, lo cual es esperado para la administración remota, pero requiere la implementación de medidas de endurecimiento estándar.

2. Hallazgos Prioritarios

- Exposición de servicios internos (resolvedor DNS local y cliente DHCP) a la red, lo que representa un riesgo crítico.
- Configuración inusual de la shell para el usuario de sistema 'User_1' (UID 4), que debería ser corregida.
- Múltiples cuentas con acceso interactivo y SSH expuesto, requiriendo un endurecimiento de la configuración SSH.

3. Matriz de Riesgos Detectados

ID	Riesgo Detectado	Nivel de Impacto	Descripción
----	------------------	------------------	-------------

R-01	Exposición de Resolvedor DNS Local (systemd-resolve)	Alto	El servicio 'systemd-resolve' (resolvedor DNS local) está escuchando en los puertos 53/tcp y 53/udp. Si estos puertos están expuestos a interfaces de red externas, un atacante podría intentar realizar ataques de denegación de servicio, envenenamiento de caché DNS o utilizar el servidor como un resolvedor abierto para ataques de amplificación.
R-02	Exposición de Cliente DHCP (systemd-network)	Crítico	El servicio 'systemd-network' (cliente DHCP) está escuchando en el puerto 68/udp. Este puerto es utilizado por el cliente DHCP para recibir ofertas del servidor DHCP y no debe estar expuesto a la red externa. Su exposición puede permitir a un atacante enviar respuestas DHCP maliciosas, realizar ataques de denegación de servicio o intentar obtener información de la red interna.
R-03	Configuración Inusual de Shell para Usuario de Sistema	Medio	El usuario de sistema 'User_1' (UID 4) tiene asignado '/bin/sync' como shell de inicio de sesión y 'tiene_login: true'. Aunque '/bin/sync' no permite una sesión interactiva, esta configuración es atípica para un usuario de sistema y podría indicar una configuración errónea o un intento de ocultar una actividad inusual. Debería ser '/usr/sbin/nologin' o similar si no se espera acceso interactivo.

R-04	Múltiples Cuentas con Acceso Interactivo y SSH Expuesto	Medio	Existen tres cuentas con shell interactiva ('root', 'User_3', 'User_4') y el servicio SSH (puerto 22/tcp) está expuesto. Aunque es una configuración estándar, la presencia de múltiples usuarios con acceso interactivo a través de SSH aumenta la superficie de ataque si las credenciales no son robustas o si no se implementan medidas de seguridad adicionales como autenticación por clave, deshabilitación de root login directo y fail2ban.
------	---	-------	--

4. Recomendaciones Técnicas de Mitigación

■ ■ Restringir el acceso al resolvedor DNS local (systemd-resolve)

El servicio 'systemd-resolve' es un resolvedor de caché local y no debe ser accesible desde la red externa. Se recomienda configurar el firewall (UFW) para bloquear el acceso a los puertos 53/tcp y 53/udp desde fuera de la máquina local y verificar que el servicio no esté configurado para escuchar en interfaces públicas.

```
sudo nano /etc/systemd/resolved.conf
Asegurarse de que la línea 'DNSStubListener=yes' esté presente y que 'DNS=' y 'FallbackDNS=' apunten a resolvedores internos
Verificar la configuración de red (ej. netplan) para asegurar que 'systemd-resolved' solo escuche en interfaces locales (127.0.0.1)
sudo systemctl restart systemd-resolved
sudo ufw deny 53/tcp
sudo ufw deny 53/udp
sudo ufw enable
```

■ ■ Bloquear el puerto del cliente DHCP (systemd-network)

El puerto 68/udp es utilizado por el cliente DHCP para recibir respuestas. No debe estar expuesto a la red externa. Un firewall debe bloquear este puerto para evitar ataques de suplantación de DHCP o denegación de servicio.

```
sudo ufw deny 68/udp
sudo ufw enable
```

■ ■ Corregir la configuración de shell para el usuario de sistema 'User_1'

El usuario 'User_1' (UID 4) tiene asignado '/bin/sync' como shell. Esto es incorrecto para un usuario de sistema que no debe tener acceso interactivo. Se recomienda cambiar su shell a '/usr/sbin/nologin' para prevenir cualquier intento de inicio de sesión.

```
sudo usermod -s /usr/sbin/nologin User_1
```

■ ■ Fortalecer la seguridad del servicio SSH

Para reducir el riesgo asociado con el acceso SSH, se recomienda deshabilitar el inicio de sesión directo como 'root', usar autenticación basada en claves SSH en lugar de contraseñas y configurar 'fail2ban' para bloquear automáticamente los intentos de inicio de sesión fallidos.

```
sudo nano /etc/ssh/sshd_config
Asegurarse de que 'PermitRootLogin no' esté configurado para deshabilitar el inicio de sesión directo como root.
Asegurarse de que 'PasswordAuthentication no' esté configurado para forzar la autenticación por clave SSH.
sudo systemctl restart sshd
sudo apt update && sudo apt install fail2ban -y
sudo systemctl enable fail2ban && sudo systemctl start fail2ban
```